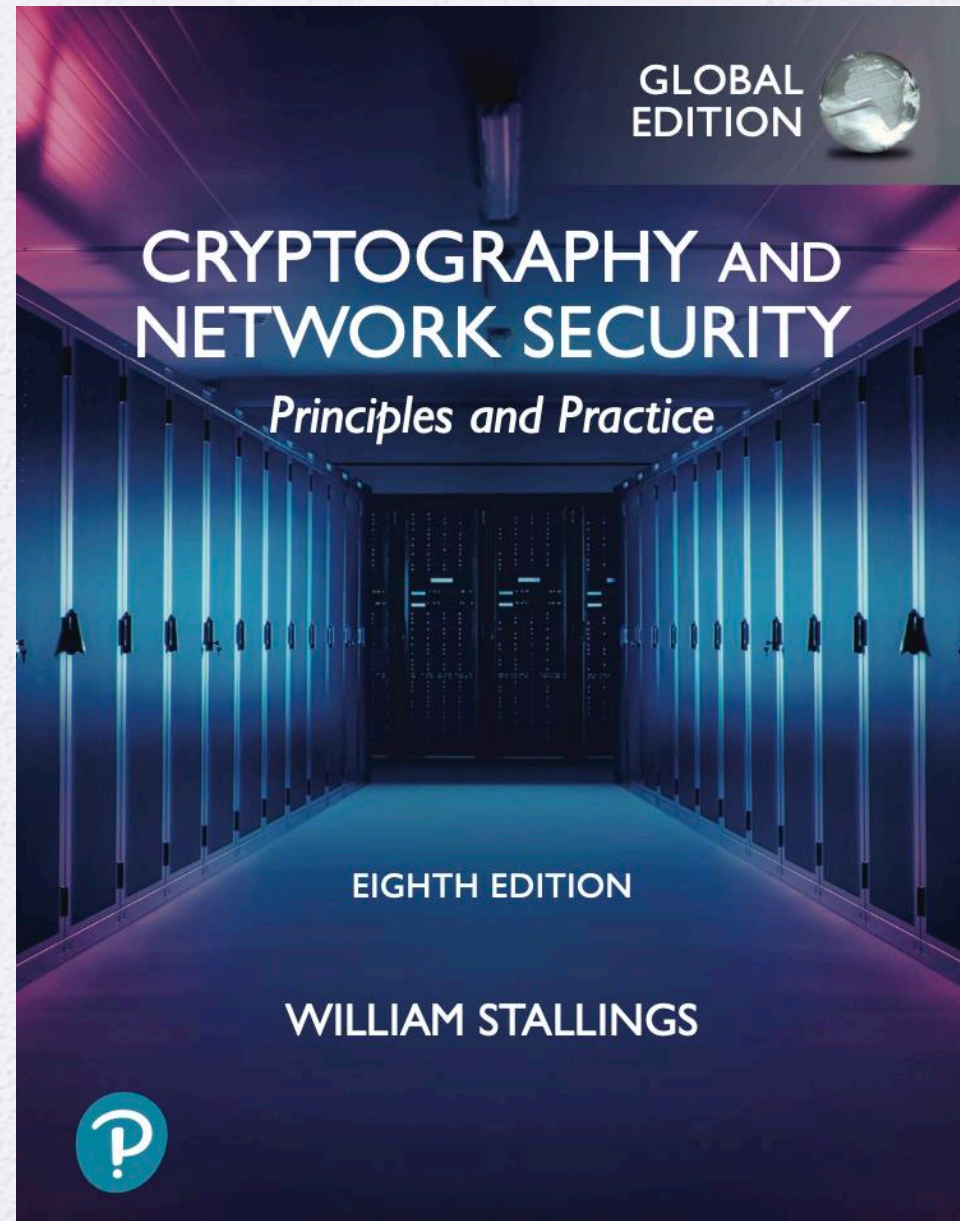


University of Nevada – Reno
Computer Science & Engineering
Department

CS454/654 Reliability and Security
of Computing Systems - Fall 2024



CLOUD SECURITY

22.1 Cloud Computing

- Cloud Computing Elements
- Cloud Service Models
- Cloud Deployment Models
- Cloud Computing Reference Architecture

22.2 Cloud Security Concepts

22.3 Cloud Security Risks and Countermeasures

- The STRIDE Threat Model
- Data Breaches
- Weak Identity, Credential, and Access Management
- Insecure APIs
- System Vulnerabilities
- Account Hijacking
- Malicious Insiders
- Advanced Persistent Threats
- Data Loss
- Insufficient Due Diligence
- Abuse and Nefarious Use of Cloud Services
- Denial-of-Service
- Shared Technology Vulnerabilities

22.4 Cloud Security As A Service

22.5 An Open-Source Cloud Security Module

22.6 Key Terms and Review Questions

Cloud Computing

Cloud Computing – a model for enabling convenient, on demand network access to a shared pool of configurable computing resources (i.e., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction.

This cloud model promotes availability and is composed of five essential characteristics, **three service models**, and **four deployment models**.

Cloud Computing

Essential characteristics of cloud computing:

Broad Network Access: capabilities are available over the network and accessed through standard mechanisms (i.e., laptops, cell phones, etc.).

Rapid Elasticity: cloud computing gives you the ability to expand and reduce resources according to requirements.

Measured Service: automatic control and optimize resources by leveraging a metering capability. Resource utilization could also be monitored, controlled and reported.

On-demand self-service: consumers can automatically provision more services (such as storage, etc.), without requiring human interaction.

Resource Pooling: multi-tenant model with different physical and virtual resources dynamically assigned and reassigned according to consumer demand.

Cloud Computing

CHAPTER 22 / CLOUD SECURITY

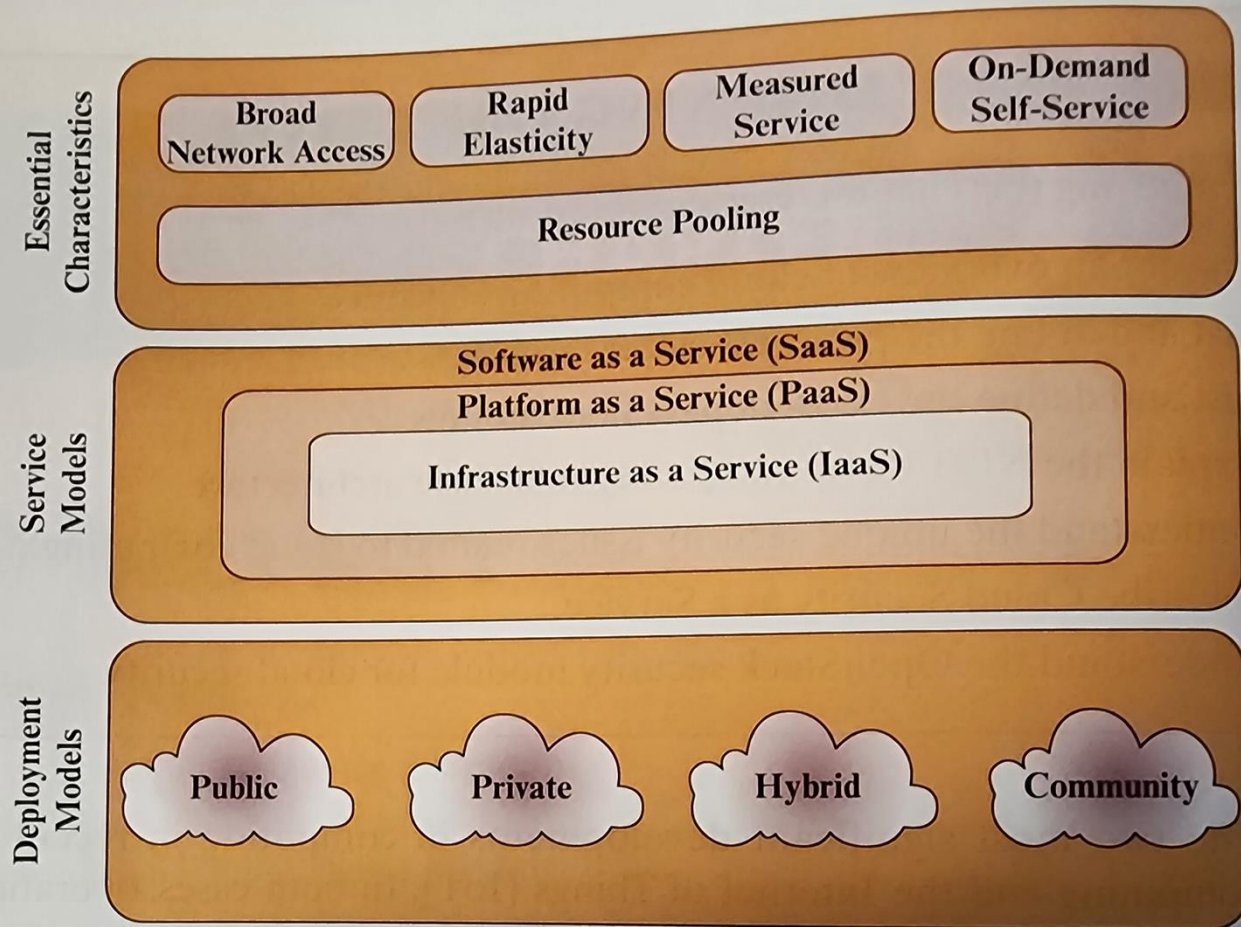


Figure 22.1 Cloud Computing Elements

Cloud Computing

702 CHAPTER 22 / CLOUD SECURITY

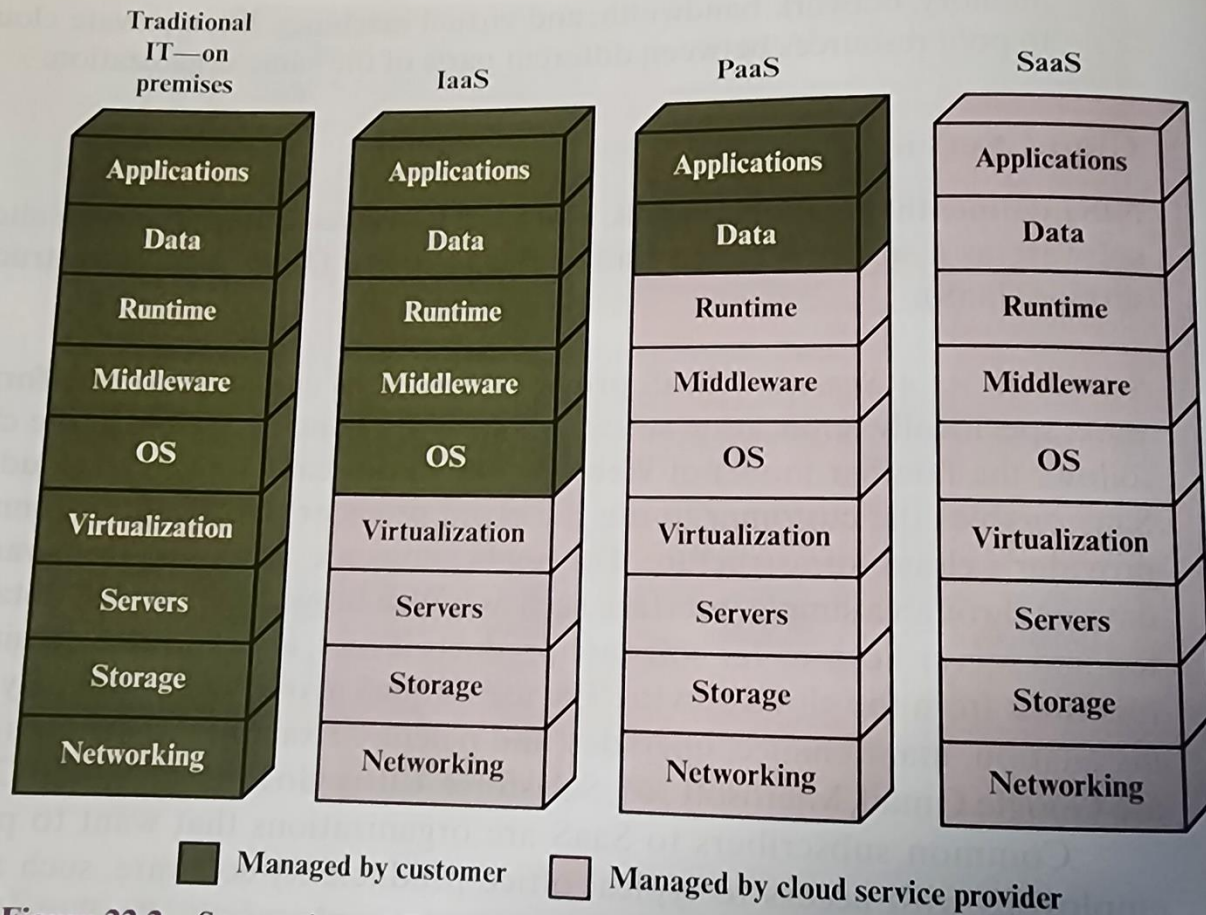
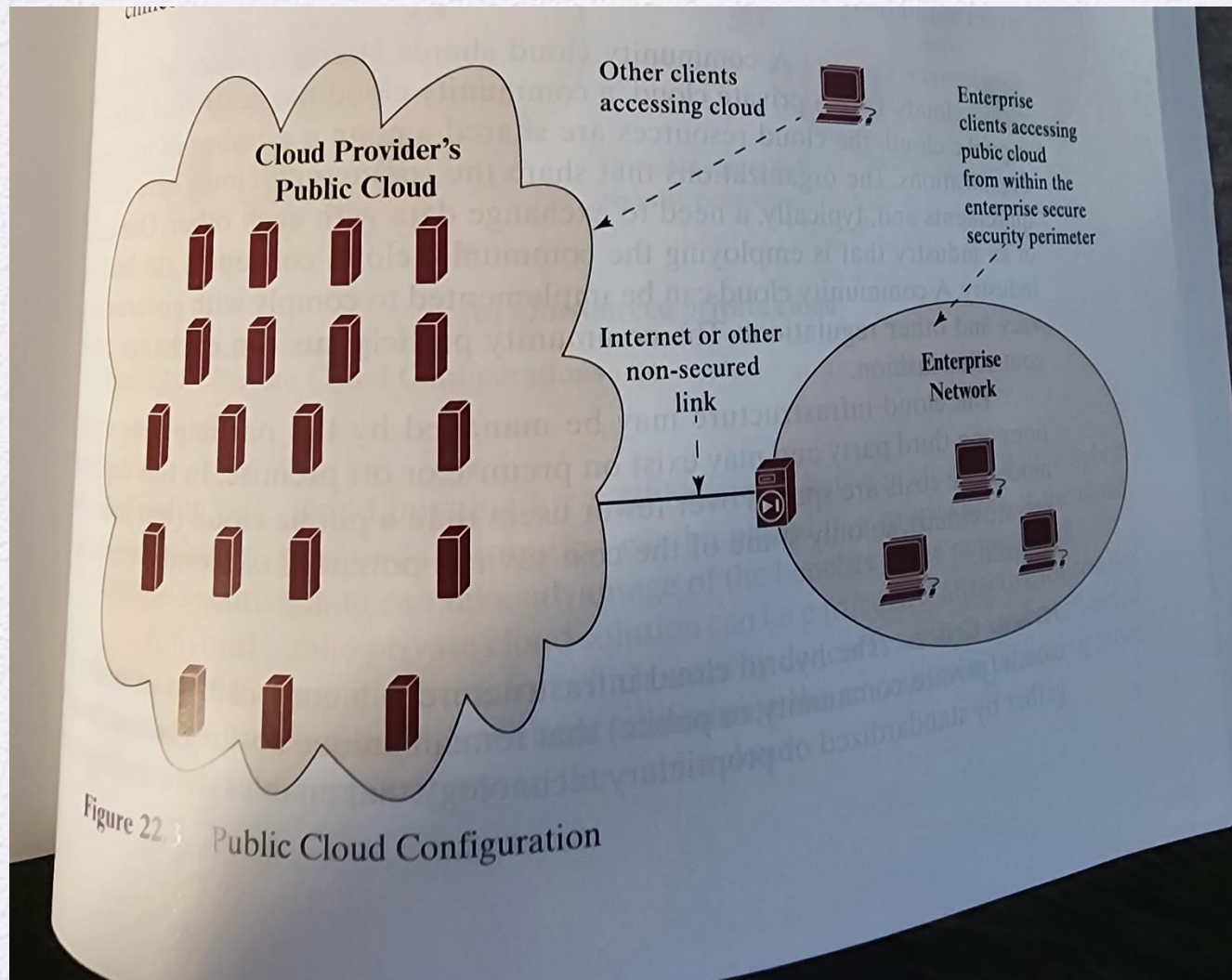
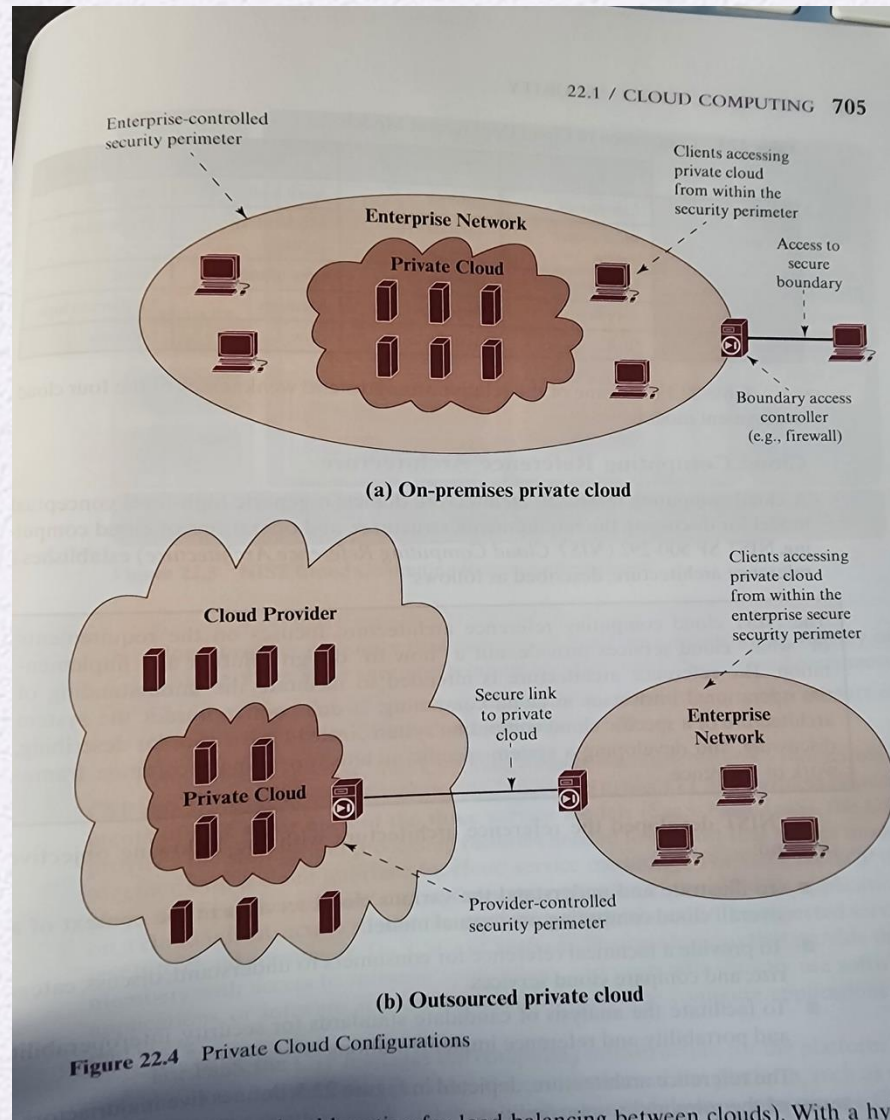


Figure 22.2 Separation of Responsibilities in Cloud Service Models

Cloud Computing – Public Cloud



Cloud Computing – Private Cloud



Cloud Computing – Deployment Model Comparison

706 CHAPTER 22 / CLOUD SECURITY

Table 22.1 Comparison of Cloud Deployment Models

	Private	Community	Public	Hybrid
Scalability	Limited	Limited	Very high	Very high
Security	Most secure option	Very secure	Moderately secure	Very secure
Performance	Very good	Very good	Low to medium	Good
Reliability	Very high	Very high	Medium	Medium to high
Cost	High	Medium	Low	Medium

Table 22.1 lists some of the relative strengths and weaknesses of the four cloud deployment models.

Cloud Computing Reference Architecture

A cloud computing reference architecture depicts a generic high-level conceptual model for discussing the requirements, structures, and operations of cloud computing (NIST SP 500-29).

Cloud Service Customer (CSC) : A person or organization that maintains a business relationship with, and uses service from, cloud providers.

Cloud Service Provider (CSP) : A person, organization, or entity responsible for making a service available to interested parties.

Cloud Auditor: A party that can conduct independent assessment of cloud services, information system operations, performance, and security of the cloud implementation.

Cloud Broker: an entity that manages the use, performance, and delivery of cloud services, and negotiates relationships between CPs and cloud customers.

Cloud Carrier: an intermediary that provides connectivity and transport of cloud services from CPs to cloud consumers.

Cloud Computing Reference Architecture

22.1 / CLOUD COMPUTING 707

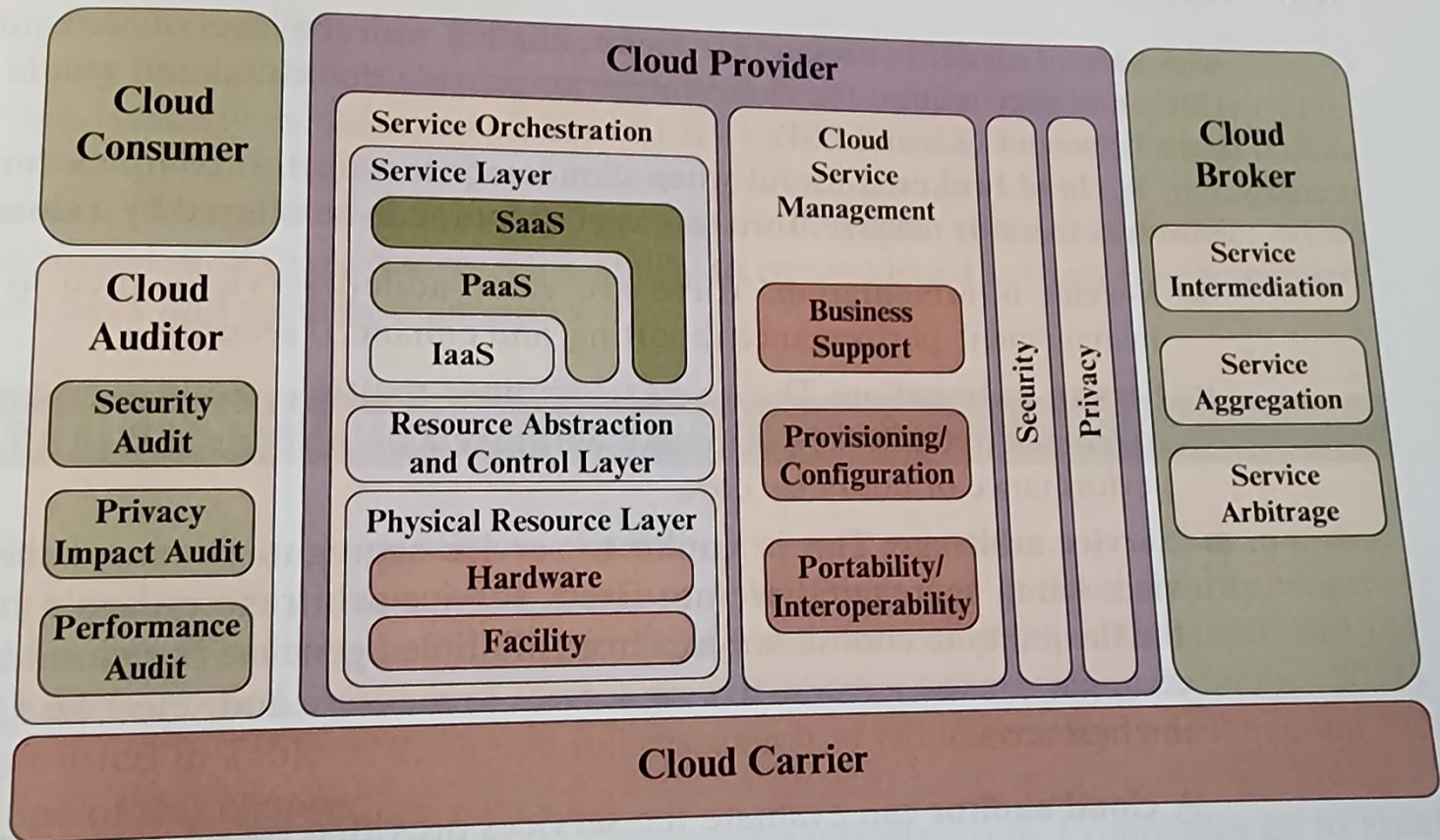


Figure 22.5 NIST Cloud Computing Reference Architecture

Cloud Security Concepts

- At large, customizable and dependent on what is running in the Cloud (i.e., ERP system, Email, Source Code Repository, etc.)
- Compliance requirements & auditability: SOC, HIPAA, SOX, GDPR, ISO, FedRamp, etc.
- Risk Assessment Considerations: cost, overall security considerations (on premise versus cloud), business continuity model (on premise versus cloud), understanding the type of deployment model versus the organizational needs and expectations.

Cloud Security Concepts

Table 22.2 NIST Guidelines on Cloud Security and Privacy Issues and Recommendations

Governance	Extend organizational practices pertaining to the policies, procedures, and standards used for application development and service provisioning in the cloud, as well as the design, implementation, testing, use, and monitoring of deployed or engaged services. Put in place audit mechanisms and tools to ensure organizational practices are followed throughout the system lifecycle.
Compliance	Understand the various types of laws and regulations that impose security and privacy obligations on the organization and potentially impact cloud computing initiatives, particularly those involving data location, privacy and security controls, records management, and electronic discovery requirements. Review and assess the cloud provider's offerings with respect to the organizational requirements to be met and ensure that the contract terms adequately meet the requirements. Ensure that the cloud provider's electronic discovery capabilities and processes do not compromise the privacy or security of data and applications.
Trust	Ensure that service arrangements have sufficient means to allow visibility into the security and privacy controls and processes employed by the cloud provider, and their performance over time. Establish clear, exclusive ownership rights over data. Institute a risk management program that is flexible enough to adapt to the constantly evolving and shifting risk landscape for the lifecycle of the system. Continuously monitor the security state of the information system to support ongoing risk management decisions.
Architecture	Understand the underlying technologies that the cloud provider uses to provision services, including the implications that the technical controls involved have on the security and privacy of the system, over the full system lifecycle and across all system components.
Identity and access management	Ensure that adequate safeguards are in place to secure authentication, authorization, and other identity and access management functions, and are suitable for the organization.
Software isolation	Understand virtualization and other logical isolation techniques that the cloud provider employs in its multi-tenant software architecture, and assess the risks involved for the organization.
Data protection	Evaluate the suitability of the cloud provider's data management solutions for the organizational data concerned and the ability to control access to data, to secure data while at rest, in transit, and in use, and to sanitize data. Take into consideration the risk of collating organizational data with those of other organizations whose threat profiles are high or whose data collectively represent significant concentrated value. Fully understand and weigh the risks involved in cryptographic key management with the facilities available in the cloud environment and the processes established by the cloud provider.
Availability	Understand the contract provisions and procedures for availability, data backup and recovery, and disaster recovery, and ensure that they meet the organization's continuity and contingency planning requirements. Ensure that during an intermediate or prolonged disruption or a serious disaster, critical operations can be immediately resumed, and that all operations can be eventually reinstituted in a timely and organized manner.

Cloud Security Concepts

22.3 / CLOUD SECURITY RISKS AND COUNTERMEASURES 711

Incident response

Understand the contract provisions and procedures for incident response and ensure that they meet the requirements of the organization.

Ensure that the cloud provider has a transparent response process in place and sufficient mechanisms to share information during and after an incident.

Ensure that the organization can respond to incidents in a coordinated fashion with the cloud provider in accordance with their respective roles and responsibilities for the computing environment.

Cloud Security Risks and Counter Measures

- The Cloud Security Alliance lists the following as the 12 top cloud-specific security threats, in decreasing order of severity:

1. Data Breaches
2. Weak identity, Credential and Access Management
3. Insecure APIs
4. System and Application Vulnerabilities
5. Account Hijacking
6. Malicious Insider
7. Advanced Persistent Threats
8. Data Loss
9. Insufficient Due Diligence
10. Abuse in use of Cloud Services
11. Denial-of-Service
12. Shared technology Vulnerabilities.

The order of severity varies organization to organization

Cloud Security Risks and Counter Measures - STRIDE

- STRIDE – Microsoft's framework to categorize attacks that arise from deliberate actions

Cloud Security Risks and Counter Measures - STRIDE

Table 22.3 Mapping Between Cloud Threats and the STRIDE Model

	S	T	R	I	D	E
Data Breaches				✓		
Weak Identity, Credential and Access Management	✓	✓	✓	✓	✓	✓
Insecure APIs		✓	✓	✓		✓
System Vulnerabilities	✓	✓	✓	✓	✓	✓
Account Hijacking	✓	✓	✓	✓	✓	✓
Malicious Insiders	✓	✓		✓		
Advanced Persistent Threats (APTs)				✓		✓
Data Loss			✓		✓	
Insufficient Due Diligence	✓	✓	✓	✓	✓	✓
Abuse and Nefarious Use of Cloud Services					✓	
Denial of Service					✓	
Shared Technology Vulnerabilities				✓		✓

S = Spoofing identity; I = Information disclosure

T = Tampering with data; D = Denial-of-service

R = Repudiation; E = Elevation of privilege.

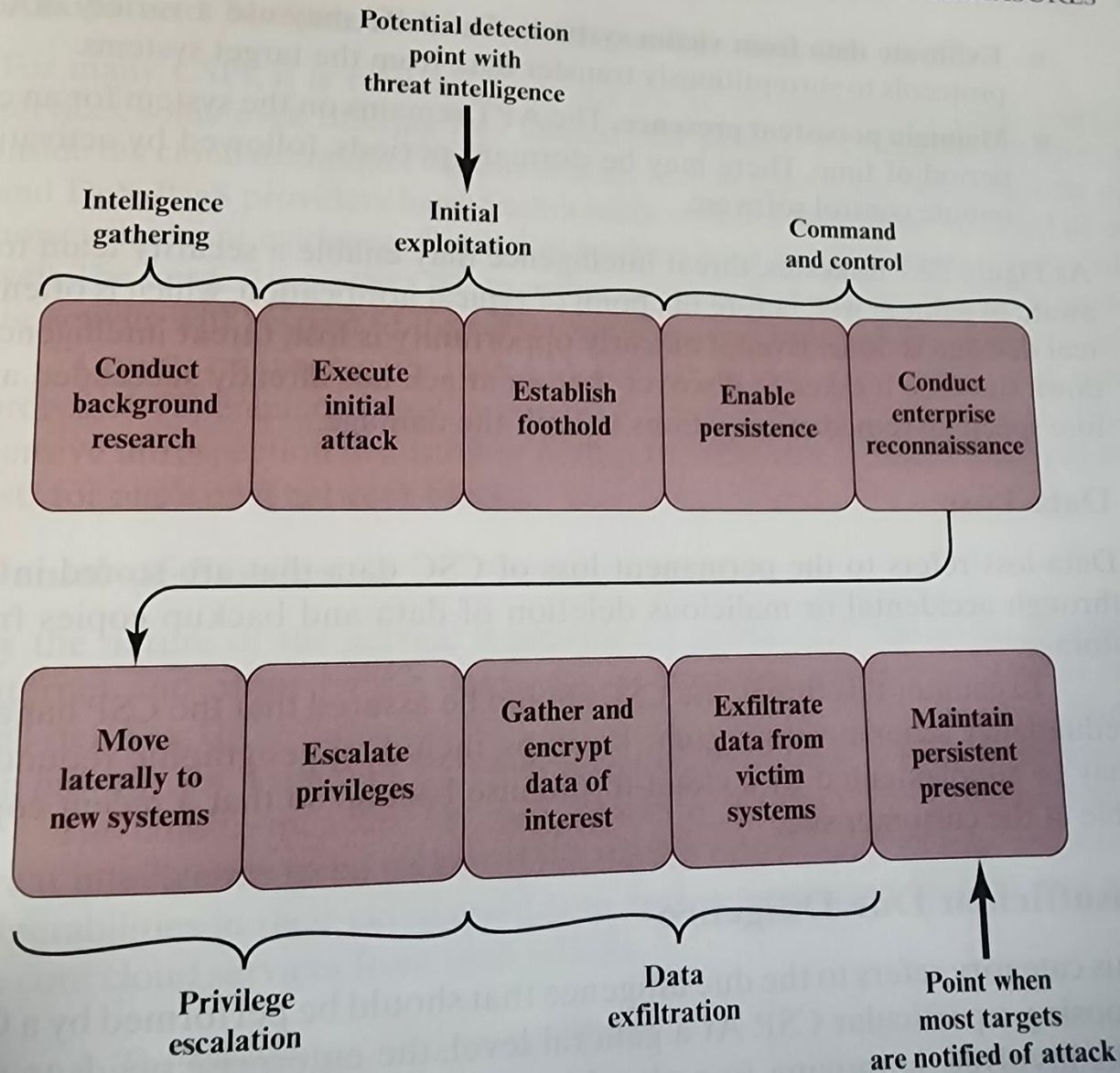
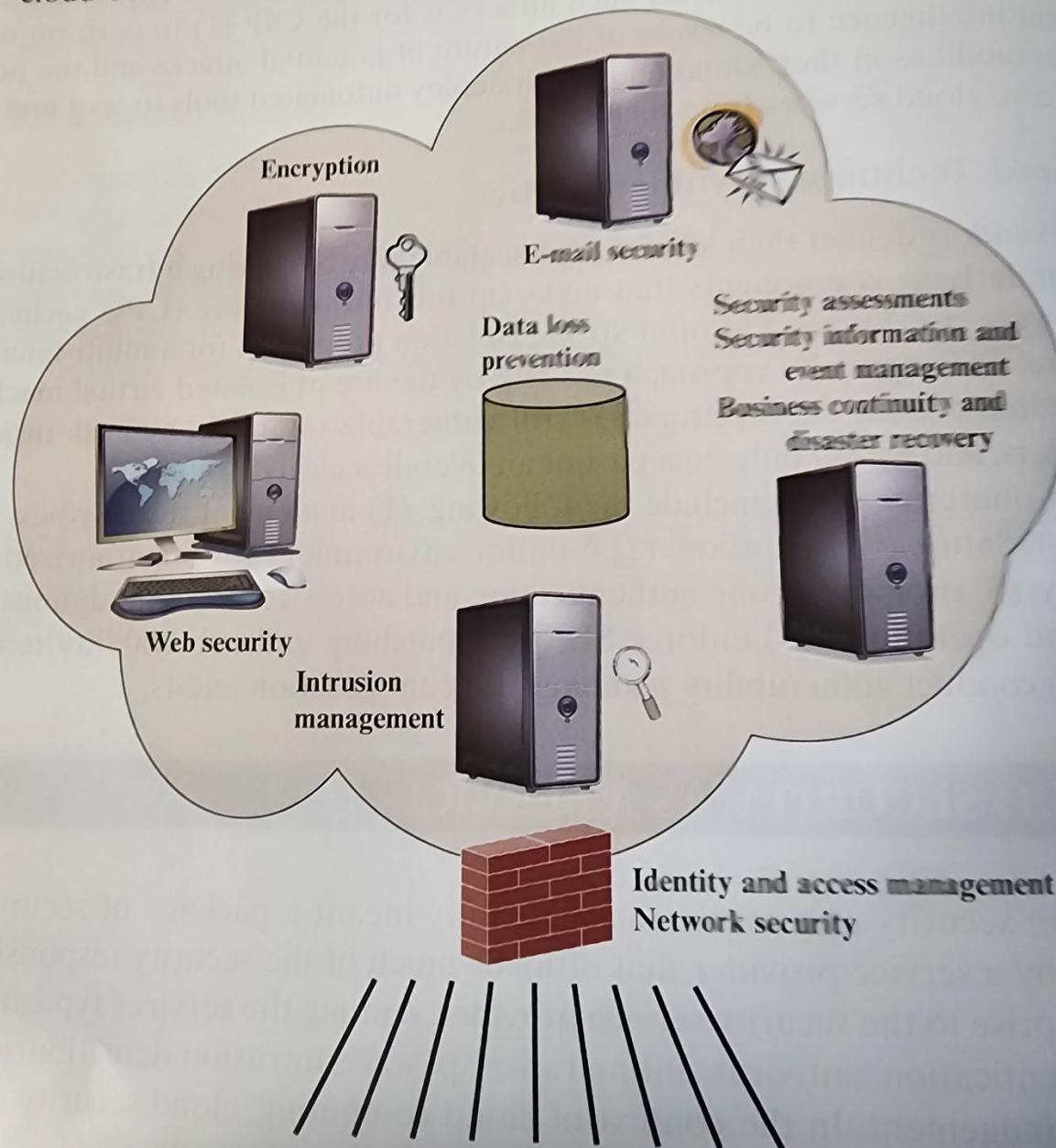


Figure 22.7 Threat Intelligence for Countering Advanced Persistent Threats



© 2020 Pearson Education, Inc. Hoboken, NJ. All rights reserved. **Figure 22.8** Elements of Cloud Security as a Service

22.6 / KEY TERMS AND REVIEW QUESTIONS

